

API SECURITY RISK ANALYSIS REPORT

Future Interns Cyber Security Internship 2026

Prepared By
Ananya Achalendran

Project
Cyber Security Task 03
API Security Risk Analysis

June 2026

INTRODUCTION

Application Programming Interfaces (APIs) are the backbone of modern web applications, mobile applications, cloud services, and Software-as-a-Service (SaaS) platforms. APIs enable communication between different software systems by exchanging data over the internet. Because APIs often expose business logic and sensitive information, they are common targets for cyberattacks. Weak authentication, excessive data exposure, insecure authorization, and missing security controls can lead to data breaches and unauthorized access.

This assessment performs a read-only security analysis of a public demonstration API to evaluate its security posture, identify potential risks, and recommend security best practices. No exploitation or unauthorized activities were performed during this assessment.

OBJECTIVE

The objective of this assessment is to perform a read-only API Security Risk Analysis on a publicly available REST API using Postman. The assessment focuses on inspecting API endpoints, request and response headers, authentication requirements, exposed data, and overall security posture.

The goal is to identify potential security risks, evaluate their business impact, and provide practical remediation recommendations based on secure API development practices.

SCOPE & METHODOLOGY

Scope

The assessment was conducted only on publicly available demonstration API endpoints provided by JSONPlaceholder.

The assessment was limited to:

- Read-only HTTP GET requests
- Response inspection
- Request and response header analysis
- Public endpoint review
- Risk identification

The following activities were intentionally excluded:

- Authentication bypass
- Exploitation attempts
- Denial-of-Service (DoS) testing
- SQL Injection
- Brute-force attacks
- Unauthorized access attempts

Methodology.

- Selected the JSONPlaceholder public API.
- Tested multiple API endpoints using Postman.
- Reviewed HTTP status codes.
- Inspected request and response headers.
- Examined returned JSON data.
- Identified potential security observations.
- Classified risk severity.
- Documented recommendations.

API OVERVIEW

The assessment was performed on JSONPlaceholder, a free REST API designed for learning, testing, and prototyping.

API Information

API Name: JSONPlaceholder

Base URL:

<https://jsonplaceholder.typicode.com>

Tested Endpoints

- GET /posts
- GET /users
- GET /todos
- GET /comments

The API is intentionally public and does not require authentication, making it suitable for educational API security assessments.

TESTED ENDPOINTS

Endpoint 1

GET /posts

- Status: 200 OK
- Authentication: Not Required
- Observation: Publicly accessible endpoint returning post data.

Endpoint 2

GET /users

- Status: 200 OK
- Authentication: Not Required
- Observation: Returns user information including names, email addresses, phone numbers, addresses, websites, and company details.

Endpoint 3

GET /todos

- Status: 200 OK
- Authentication: Not Required
- Observation: Returns publicly accessible task information.

Endpoint 4

GET /comments

- Status: 200 OK
- Authentication: Not Required
- Observation: Returns public comment information.

POSTMAN REQUEST & RESPONSE

EVIDENCE

The selected API endpoints were tested using Postman.

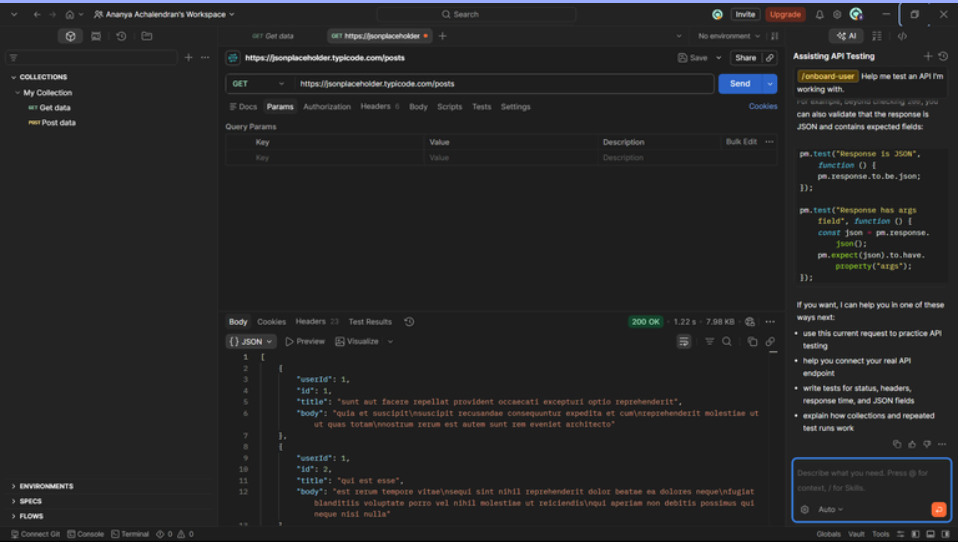
The following evidence was collected during testing:

- GET /posts request and response
- GET /users request and response
- GET /todos request and response
- GET /comments request and response
- Request header inspection
- Response header inspection

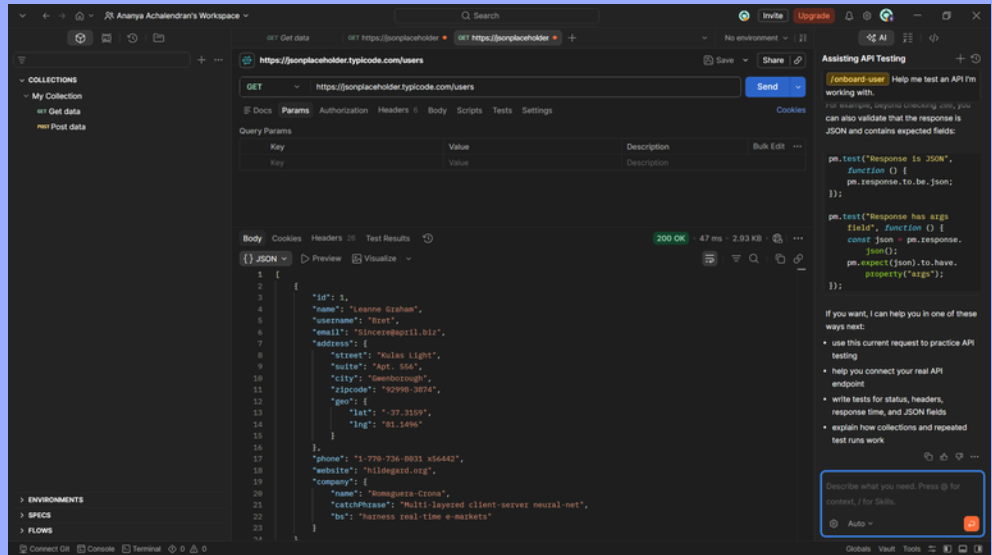
Each request returned an HTTP 200 OK status, confirming successful communication with the API server.

Representative screenshots are included throughout this report.

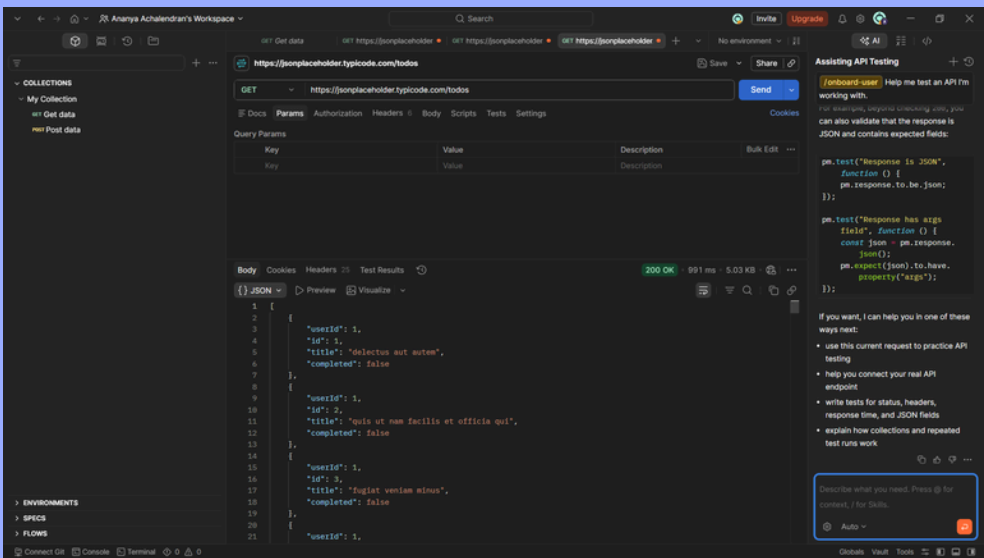
postman_get_posts.png



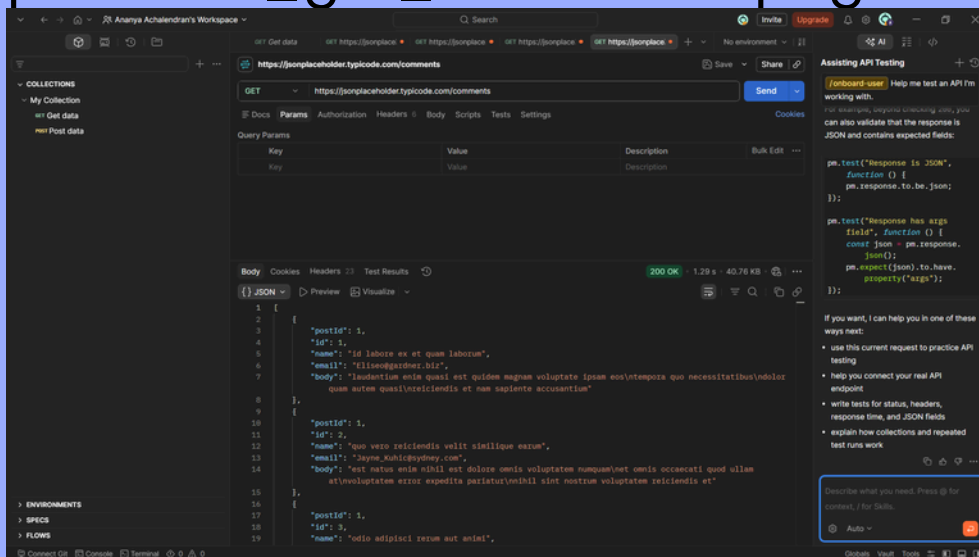
postman_get_users.png



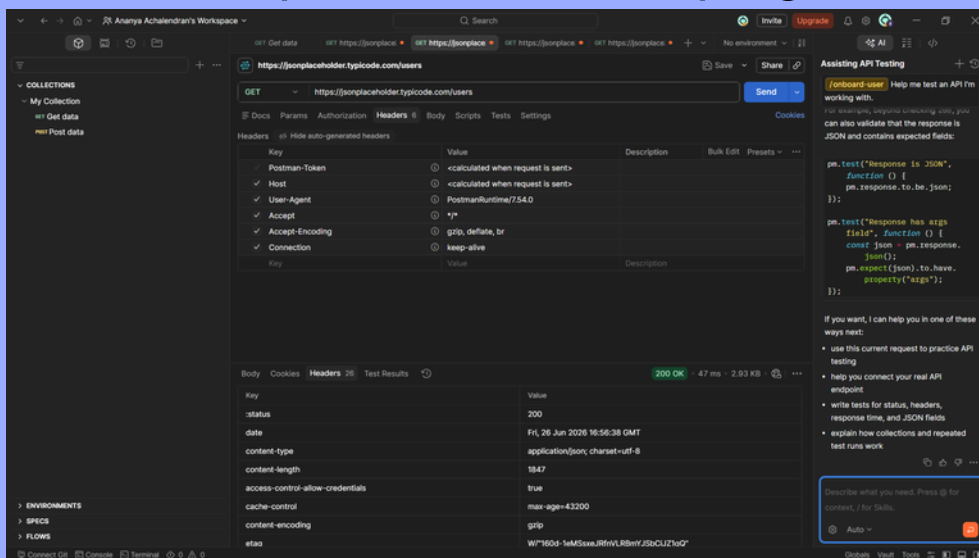
postman_get_todos.png



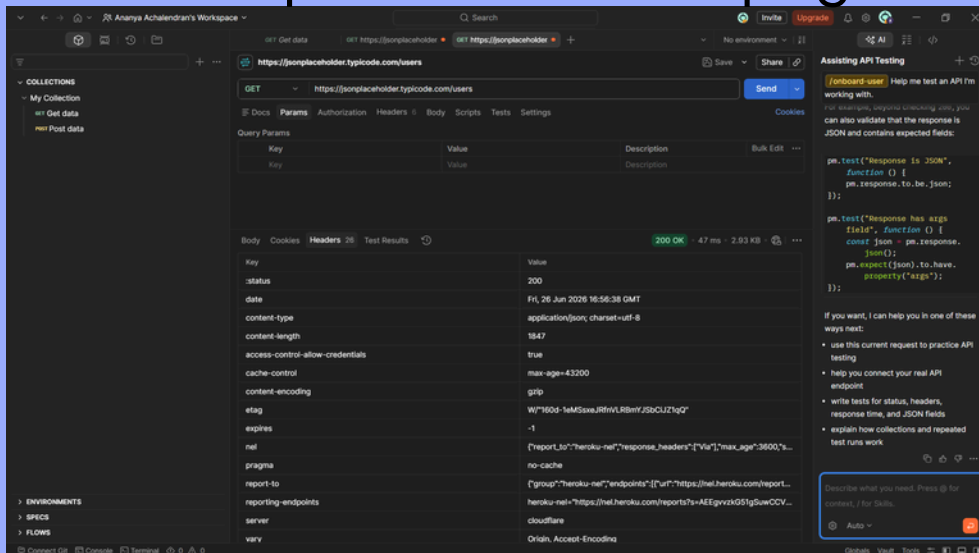
postman_get_comments.png



users_request_headers.png



users_response_headers.png



SECURITY FINDINGS

Finding 1 – Public API Endpoints

Risk Level: Low

The tested endpoints were publicly accessible without authentication. This behavior is expected for a demonstration API but should be carefully controlled in production environments.

Finding 2 – User Information Exposure

Risk Level: Medium

The /users endpoint exposes user-related information such as names, email addresses, phone numbers, addresses, websites, and company details. In a production environment, exposing such information without authentication may increase privacy and security risks.

Finding 3 – Missing Authentication

Risk Level: Low

No authentication mechanisms were observed during testing. This is appropriate for a public demo API but would not be suitable for APIs handling sensitive information.

Finding 4 – Response Header Inspection

Risk Level: Informational

Response headers were inspected to identify security-related information. No sensitive server-side information was observed in the responses.

Finding 5 – Rate Limiting

Risk Level: Medium

Rate limiting information was not clearly documented. Production APIs should implement request throttling to protect against abuse and excessive requests.

BUSINESS IMPACT

If similar observations were found in a production API, they could result in:

Unauthorized access to user information.

Increased risk of data harvesting.

Privacy concerns.

Social engineering opportunities.

Abuse through excessive automated requests.

Increased operational and reputational risks.

Although the assessed API is intentionally public, these observations highlight important security considerations for real-world applications.

REMEDIATION RECOMMENDATIONS

The following recommendations are suggested to improve API security in production environments:

- Implement strong authentication mechanisms such as OAuth 2.0 or JWT.
- Apply role-based access control (RBAC) to protect sensitive resources.
- Return only the minimum data required by clients.
- Implement API rate limiting and throttling.
- Validate and sanitize all user inputs.
- Monitor API activity through centralized logging and auditing.
- Enforce HTTPS for all API communications.
- Regularly review APIs against the OWASP API Security Top 10 guidelines.

CONCLUSION

This assessment successfully evaluated multiple endpoints of the JSONPlaceholder demonstration API using safe, read-only testing techniques.

The tested API functioned as intended and returned successful responses. No critical vulnerabilities were identified during the assessment. However, observations such as public endpoint accessibility, user information exposure, and the absence of authentication highlight important considerations for production APIs.

Overall, the API is suitable for educational purposes and demonstrates common API structures while emphasizing the importance of implementing appropriate security controls in real-world environments.